

Lock down your VM with a firewall

Session 4 – Networking & firewall controls

Exercise 4 · Session 4 lab · Estimated time: 75–100 min

Write your answers in the answer document `SKY2100_Exercise4_Answers.docx`. Last week you saw what *too much* traffic does; today you control *which* traffic is allowed at all. You will turn your Ubuntu VM into a **default-deny** host with UFW, open only the ports you can justify, and prove the rules work by testing from the host. This is the same reasoning you will later apply to an Azure Network Security Group.

Caution: Keep the SSH port (22) open throughout. If you are working on a remote VM, closing it can lock you out. Test changes locally first.

1 Baseline: what is open now?

▷ List the ports your VM is currently listening on:

`ss -tulpn`. Note which services are bound to all interfaces (`0.0.0.0 / [:::]`) versus localhost only.

▷ For each listening port, decide: does it need to be reachable from outside?

2 Configure a default-deny firewall

▷ Set the policy and open only what you need:

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
sudo ufw enable
```

▷ Inspect the result:

`sudo ufw status verbose`. Which ports did you allow, and why exactly those?

3 Test that the rules actually work

▷ Start a web server if one is not running

(`sudo apt install -y nginx`) and find the VM's address with `ip a`.

▷ Test from your *host* machine, not from inside the VM

— UFW does not filter loopback traffic, so `localhost` would never show a block. On the host, test an *allowed* and a *denied* port:

```
curl -I http://<vm-ip>:80 (# allowed -> responds)
curl -max-time 5 http://<vm-ip>:8080 (# denied -> times out)
```

Note: VirtualBox users: VirtualBox NAT is not reachable from the host — switch the VM's network adapter to *Bridged* or *Host-only* first. VMware NAT works as it is.

▷ For comparison, disable the firewall for a moment

(`sudo ufw disable`), repeat the second `curl`, then `sudo ufw enable` again. Without the firewall, the closed port answers “connection refused” at once.

▷ Briefly, what is the difference between how a *denied* port and a *closed* port fail? (timeout vs. connection refused)

▷ Re-run `ss -tulpn` and compare with your baseline.

Key idea: Compare the two `ss` outputs: they are almost identical. The firewall did not stop a single service from running; every daemon still listens exactly as before. What changed is who can reach it from outside. A firewall controls reachability, not whether software runs, and that distinction is the whole point of the attack-surface idea from the lecture: the service is still there, you have just shut the door in front of it. The two failures you saw also differ for a reason worth remembering. A closed port with no firewall in the way answers with a quick “connection refused”, while a port the firewall drops simply times out, because the packet is silently discarded and the attacker is left waiting with no reply.

4 Cloud transfer: Microsoft Learn

▷ Revisit “Describe Azure networking services”

and focus on **Virtual Network (VNet)** and **Network Security Group (NSG)**.

learn.microsoft.com/training/modules/describe-azure-networking-services

▷ Map your UFW rules to an NSG.

For each rule — `allow 22/tcp` (SSH), `allow 80/tcp` (HTTP) and the default deny — write in the answer document what the equivalent NSG rule would look like.

5 Azure reflection

▷ An NSG protects a whole subnet; UFW protects one host. Why is running *both* an example of defence in depth, rather than redundant effort?

6 Knowledge check

1. What does a socket consist of?

- ☐ an IP address only ☐ a port only ☐ an IP address + a port ☐ a MAC address + a port

Hint: Two things together: which machine, and which program on it.

2. Why is **default-deny** the only safe default policy for a firewall?

Hint: You cannot foresee every threat, so you open only what you can justify.

3. Which port is which? 22 = _____; 80 = _____; 443 = _____; 53 = _____.

Hint: 22, 80, 443, 53 — match them to SSH, HTTP, HTTPS, DNS.

4. State the difference between a **stateless** and a **stateful** firewall, and say which UFW and NSGs are.

Hint: One judges each packet alone; one remembers active connections.

5. In a firewall rule, name the five things a rule typically specifies.

Hint: Action, protocol, source, destination, port.

6. What is the security benefit of **NAT**, even though it is not a firewall?

Hint: It hides internal machines behind one public address.

7. Explain **network segmentation** and how it limits “lateral movement”.

Hint: Separate zones, so a breach in one cannot roam into the others.

8. True or false: a host firewall is unnecessary if there is a network firewall in front of it. Justify.

Hint: Defence in depth — what if the network firewall is bypassed or misconfigured?

9. What problem does a **bastion** / **jump host** solve?

Hint: One hardened, watched entry point instead of exposing every host to SSH.

10. In Azure, NSG rules are evaluated by _____; the _____ match wins.

Hint: By priority, lowest number first; the first match wins.

11. Why does **SDN** make a cloud network both easier to secure *and* riskier? (one line)

Hint: Central control can program the whole network at once — powerful, and a target.

12. (Reflection) Which single listening port on your VM would you remove first, and why?

Progress check: Discuss your answers in the group, then talk the teacher through them verbally at the next session only to track progress; nothing is handed in, signed or graded.

Solutions

Work through the lab first, then check here. Model answers are indicative — equivalent reasoning is fine.

Note: Model answers are indicative – accept equivalent reasoning. Multiple-choice answers are in **bold**.

Knowledge check

1. **An IP address + a port.**
2. Because you cannot anticipate every threat. With default-deny you open only what you can justify, so anything unforeseen is blocked automatically – the principle of least exposure.
3. 22 = **SSH**; 80 = **HTTP**; 443 = **HTTPS**; 53 = **DNS**.
4. **Stateless** judges each packet in isolation; **stateful** tracks active connections and automatically allows replies to traffic you started. UFW and NSGs are **stateful**.
5. **Action** (allow/deny), **protocol** (TCP/UDP), **source**, **destination**, and **port**.
6. NAT hides internal machines behind one public address; they are not directly reachable from outside unless a port is explicitly forwarded – a crude but real first barrier. (Comer Ch. 7, p. 91, verified.)
7. **Segmentation** divides the network into separate zones so a breach in one cannot freely reach the others, limiting *lateral movement*. (CSA Domain 7; Comer VLAN/VXLAN p. 89–90.)
8. **False** – defence in depth. The host firewall still protects the host if the network firewall is bypassed or misconfigured, or if the threat originates *inside* the network.
9. A **bastion** / **jump host** provides a single hardened, heavily-monitored entry point for admin access (SSH), instead of exposing SSH on every server.
10. Rules are evaluated by **priority** (lowest number first); the **first** match wins.
11. SDN centralises and programs the network, so a policy can be applied everywhere at once (easier to secure); but the controller is a single high-value target and a misconfiguration propagates just as fast (riskier). (Comer Ch. 7, p. 94–95, verified.)
12. Reflection – no fixed answer; expect students to name an unneeded service bound to a public interface.

Lab checkpoints

- `ufw status verbose` should show *default deny (incoming)* plus explicit allow rules for 22 and 80.
- Tested from the host: an allowed port responds to `curl`; a port the firewall drops *times out*; with UFW disabled the same closed port answers *connection refused* at once – a good discussion point. Testing against `localhost` inside the VM proves nothing, because UFW does not filter loopback traffic.
- The before/after `ss -tulpn` should be unchanged (services still listen); the firewall controls *reachability*, not whether a service runs.

References

CSA Security Guidance v5, **Domain 7: Infrastructure & Networking** (verified); Comer Ch. 7 (NAT **p. 91**, VLANs **p. 89**, VXLAN **p. 90**, virtual switch **p. 91**, SDN **p. 94**, OpenFlow **p. 95**) – all verified; Jøsang Ch. 6 (syllabus, page numbers not verified). MS Learn: *Describe Azure networking services* (verified, June 2026).